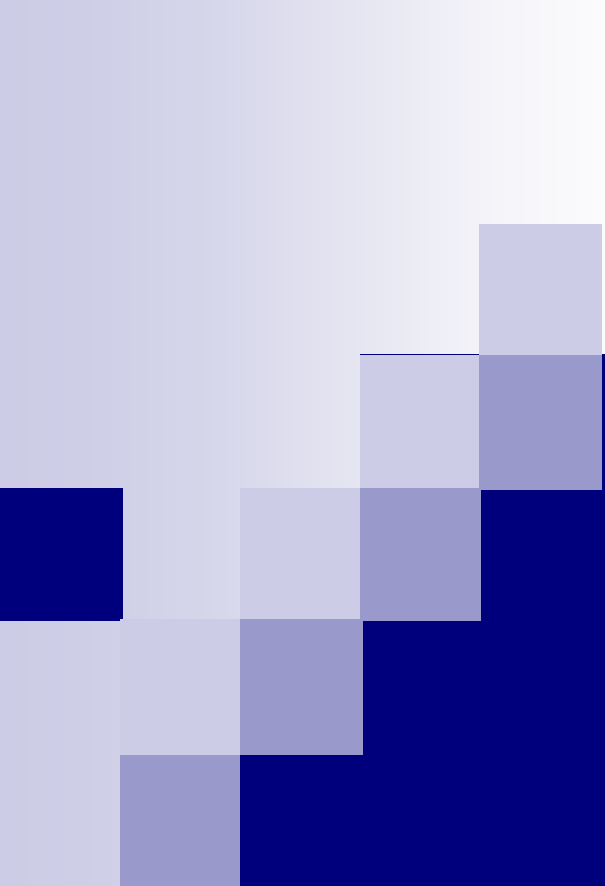




网络空间安全 战略思考与启示

国家信息化专家咨询委员会委员

沈昌祥 院士

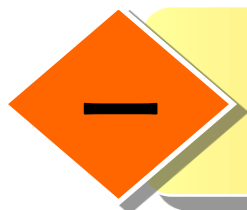


**没有网络安全，
就没有国家安全**

美国组建了网络安全司令部，颁布了作战策略，“棱镜”微不足道！

美国意图：确立霸主，制定规则，谋求优势，控制世界

斯诺登只是揭穿了美国和平发展网络的假面具



美国网络空间安全战略启示

（一）美国将网络空间安全由“政策”、“计划”提升为国家战略

1998年5月，当时的克林顿政府发布了第63号总统令（PDD63）：《克林顿政府对关键基础设施保护的政策》，成为直至现在美国政府建设网络空间安全的指导性文档

2000年1月，克林顿政府发布了《信息系统保护国家计划v1.0》，提出了美国政府在21世纪之初若干年的网络空间安全发展规划

2001年10月16日，布什政府意识到了911之后信息安全的严峻性，发布了第13231号行政令**《信息时代的关键基础设施保护》**，宣布成立“总统关键基础设施保护委员会”，简称PCIPB，代表政府全面负责国家的网络空间安全工作。委员会由克拉克担任主席

该委员会与2002年9月18日制定发布了**《保护网络空间的国家战略》（草案）**

经征求意见修改后，于2003年2月正式发表

2003年12月17日发布了《**第7号国土安全总统令**》，重新对关键基础设施和资源进行标识、优先级排序和防护，要求国防部建立合适的系统、机制和流程与其他部门进行协调和沟通。以反恐名义立法，全面监控网络信息。

2005年4月14日，美国政府公布了美国总统IT咨询委员会2月14日向总统布什提交的《**网络空间安全：迫在眉睫的危机**》的紧急报告，对美国2003年的网络空间安全战略提出不同看法，指出过去十年中美国保护国家信息技术基础建设工作是失败的。短期弥补修复不解决根本问题。GIG耗资一千亿美元，而安全漏洞百出

2006年4月信息安全研究委员会发布的
《联邦网络空间安全及信息保障研究与发
展计划（CSIA）》确定了14个技术优先研
究领域，13个重要投入领域。改变无穷无
尽打补丁和封堵的被动防御策略

2008年1月，美国发布了机密级的**第54号国家安全总统令**（同时也编号为第23号国土安全总统令），通过该令设立了“**综合性国家网络安全计划**”，提出了很多新的政策与行动计划，还扩展了国家安全局对政府信息系统安全的主管权力

最近解密了《网络安全计划摘要》，提出“曼哈顿”计划（二战研制原子弹）。工程计划以“爱因斯坦”命名，全面建设联邦政府和主要信息系统的防护系统，建立全国统一的安全态势信息共享和指挥系统

(二) 美国网络空间安全的战略完善

(1) 《提交第44届总统的保护网络空间安全的报告》

美国在2007年8月成立了第44届总统网络空间安全委员会，经过一年半的工作，形成了《提交第44届总统的保护网络空间安全的报告》

报告引言：**暗战**，以二战时期“阿尔法和英格码”事件为警示，提出：网络安全是美国在一个竞争更加激烈的新国际环境中面临的**最大安全挑战之一**。美国处于英格码被破境地

“是一场黑暗中进行的战争，一场我们正在输掉的战争”

“在网络空间，战争已经开始”，美国国防部已进行了广泛的部署，为网络空间可能发生的冲突做准备

最后，建议建立特种技术部队

报告提出了十二项、25条建议，分别从制定战略、设立部门、制定法律法规、身份管理、技术研发等方面进行了阐述

(2) 奥巴马政府的战略举措

2008年12月，为了加深美国政府对信息安全现状的认识，美国开展了为期2天的“模拟网络战”，总计有230名来自军方、政府和企业的代表参与了这次演习活动

演习结果认为，美国在网络攻击前抵抗能力很差，这为奥巴马政府敲响了警钟

2009年2月9日，奥巴马指示美国国家安全委员会和国土安全委员会负责网络空间事务的代理主管梅利萨·哈撒韦主持组织对美国的网络安全状况展开为期60天的全面评估

经过几个月的工作，2009年5月29日，奥巴马在白宫东厅公布了名为《网络空间政策评估——保障可信和强健的信息和通信基础设施》的报告，并发表重要讲话

奥巴马在演讲词中强调，美国21世纪的经济繁荣将依赖于网络空间安全

他将网络空间安全威胁定位为“我们举国面临的最严重的国家经济和国家安全挑战之一”，并宣布“从现在起，我们的数字基础设施将被视为国家战略资产。保护这一基础设施将成为国家安全的优先事项”，白宫必须领导前进的道路

报告提出了10条近期行动计划和14条中期行动计划，全面规划了保卫网络空间的战略措施

2009年6月23日，美国国防部长罗伯特·盖茨正式发布命令建立美国“**网络空间司令部**”，以统一协调保障美军网络安全和开展网络战等与网络有关的军事行动

2010年5月21日，美国网络司令部正式启动，隶属于美国战略司令部，编制近千人，很快投入全面运作

（三）网络空间国际和战争战略

2011年5月16日，美国白宫网络安全协调员施密特发布美国首份《**网络空间国际战略**》，阐述美国“在日益以网络相联的世界如何建立繁荣、增进安全和保护开放”

施密特将这份战略文件称为美国在21世纪的“历史性政策文件”。该战略文件称，美国希望打造“**开放、可共同使用、安全、可信赖**”的国际网络空间，并将综合利用外交、防务和发展手段来实现此目标

“对于任何攻击网络空间的敌对行动，美国将视其等同于威胁美国国家安全行为……，将运用军事力量回击……，并保留使用包括外交、情报、军事以及经济上一切必要手段的合理权利”

总意图： 确立霸主，制定规则，谋求优势，控制世界

2011年7月14日，美国国防部发布了《**网络空间行动战略**》再次强调：“网络安全威胁是我们作为一个国家所面临的最严重的国家安全、公共安全和经济安全挑战”

该战略将指导美国国防部捍卫美国在网络空间的利益，使得美国及其盟国和国际合作伙伴可以继续从信息时代的创新中获益

五大战略措施：

1

将把网络空间视为一个行动领域，有效组织、训练和装备

2

将采用新的国防战略思想，以保护美国国防部的网络和系统

3

将与其他政府部门和私营机构一起，实现一体化政府网络空间安全战略

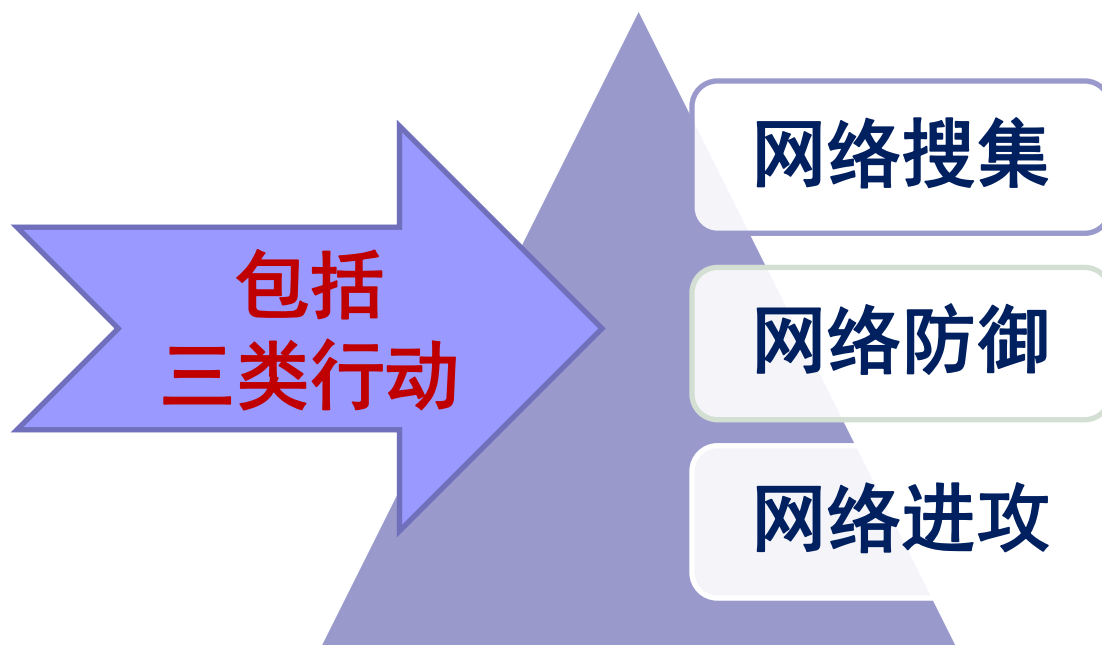
4

将建立与其它联盟和国际伙伴的强大合作关系，以加强网络空间安全

5

将通过一支卓越的网络行动队伍和高效的技术创新能力，巩固国家在网络空间中的优势地位

2012年10月16日，奥巴马签署了《**美国网络行动政策**》(PDD21)，在法律上赋予美军具有进行非传统作战权力，明确从网络中心战扩展到网络空间作战行动等



2013年2月12日，奥巴马发布了第13636号行政命令 **《增强关键基础设施网络安全》**，明确指出，“这是美国提升国家关键基础设施并维护环境安全与恢复能力的政策，在提升安全性、商业机密、隐私和公民自由的同时提升效率、创新与繁荣”

2013年4月10日，奥巴马向国会提交《2014财年国防预算优先项和选择》提出，至2016年整编成133支网络部队

包括

- 国家任务部队68支
- 作战任务部队25支
- 网络防御部队40支

2014年2月12日，美国国家标准与技术研究所针对《增强关键基础设施网络安全》，提出了《美国增强关键基础设施网络安全框架》（V1.0），强调利用业务驱动指导网络安全行动，并考虑网络安全风险作为组织风险管理进程的一部分

最近北约网络空间安全框架指出，目前世界上有一百多个国家具备一定的网络战能力，公开发表网络安全战略的国家多达50多家

启示

美国网络空间战略表明，网络空间已经成为陆、海、空、天之后的第五大主权领域空间，也是国际战略在军事领域的演进，对我国网络安全提出了严峻的挑战。我们应积极应对，加快建设我国网络安全保障体系，捍卫我国网络安全国家主权

二

构建主动防御的技术保障体系

（一）可信免疫的计算体系结构

当前安全防护的倾向

当前大部分网络安全系统主要是由防火墙、入侵监测和病毒防范等组成，称为“老三样”

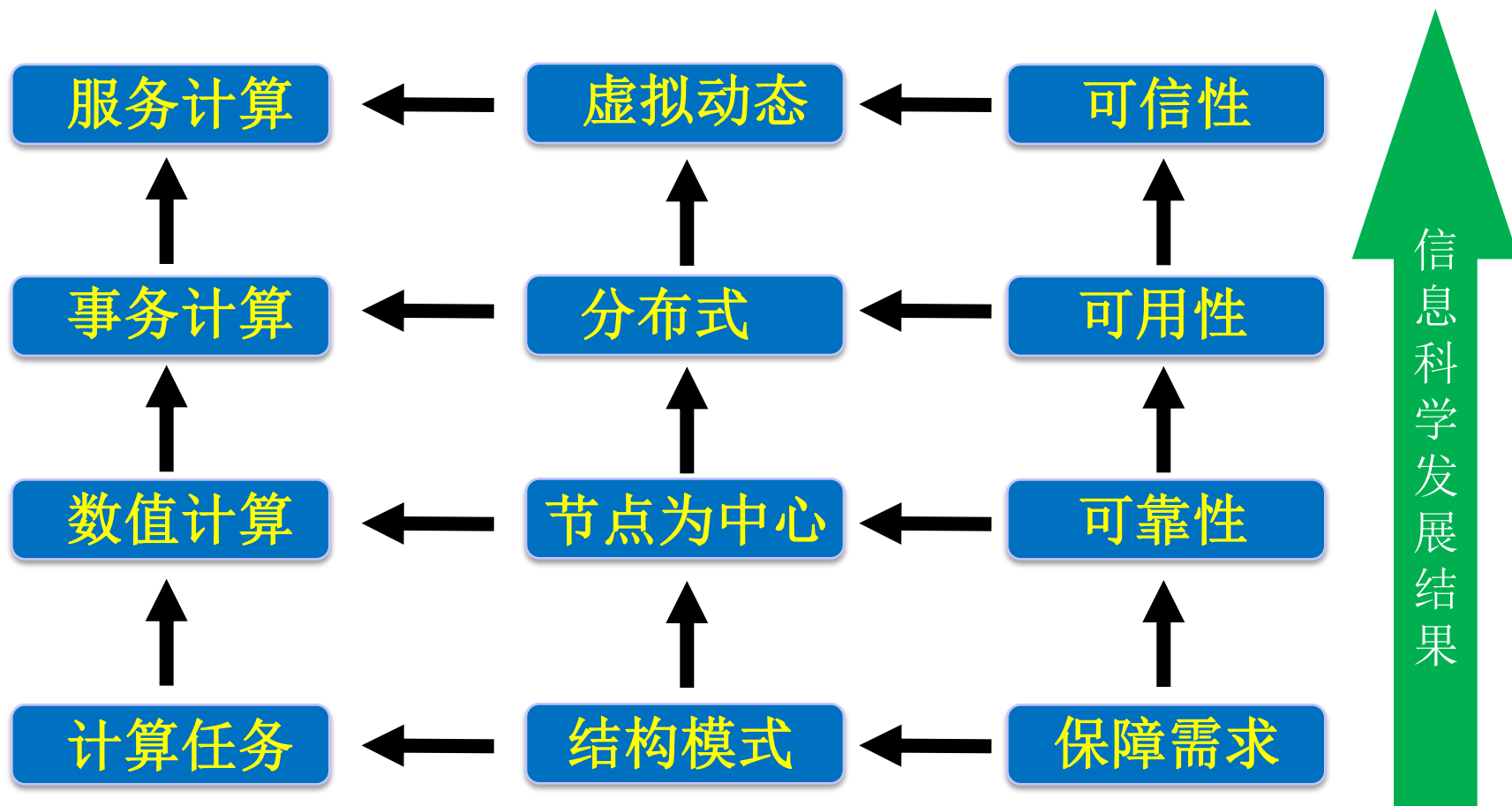
消极被动的封堵查杀是防不胜防的

(1) 可信免疫的计算模式

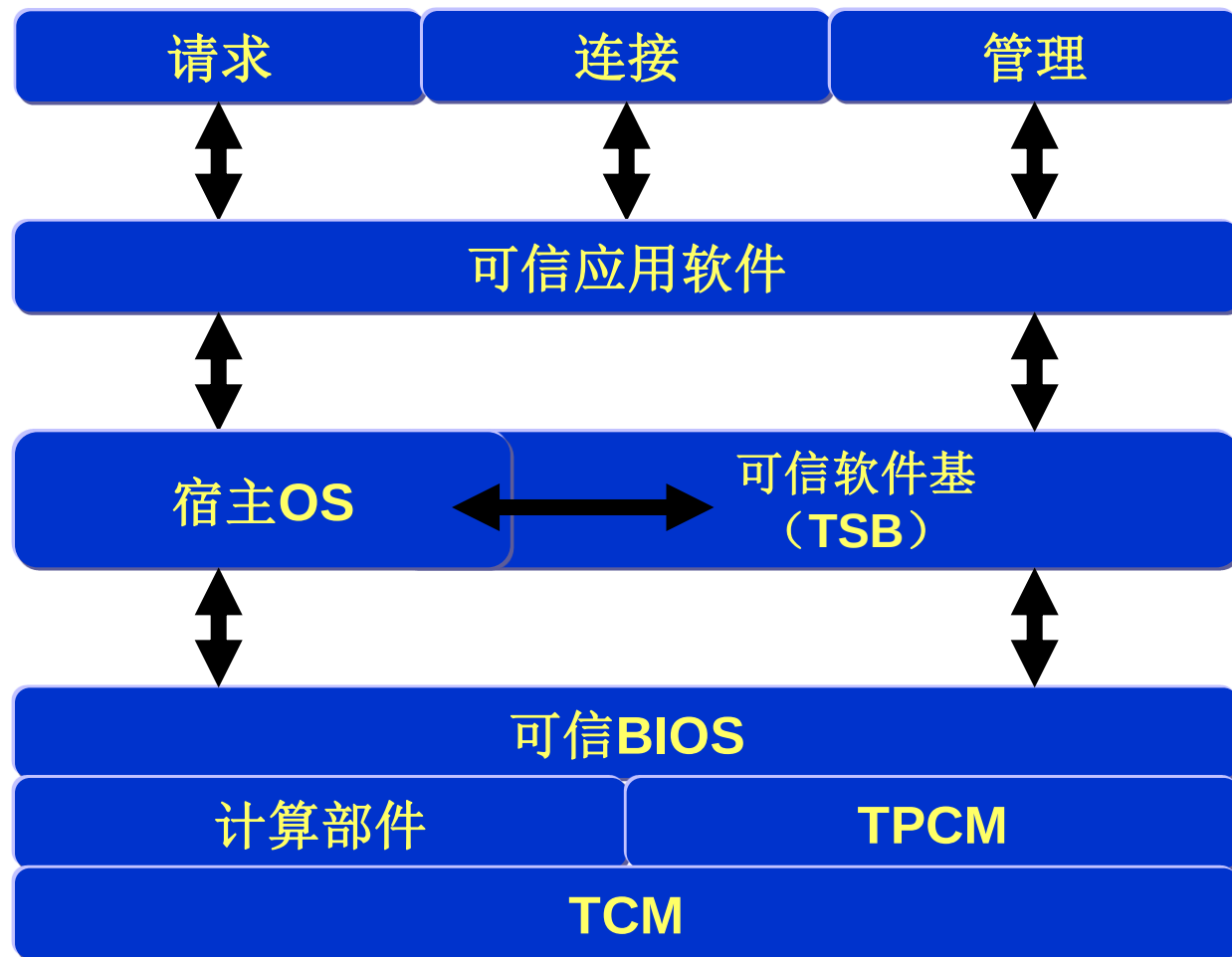
可信计算是指计算运算的同时进行安全防护，使计算结果总是与预期一样，计算全程可测可控，不被干扰

是一种运算和防护并存的主动免疫的新计算模式，及时识别“自己”和“非己”成份，从而破坏与排斥进入机体的有害物质

可信计算是信息科学发展结果



建立运算和防御并行的双体系结构



双体系结构

(2) 安全可信系统框架

云计算、大数据、移动互联网、虚拟动态异构计算环境更需要可信

体系结构可信

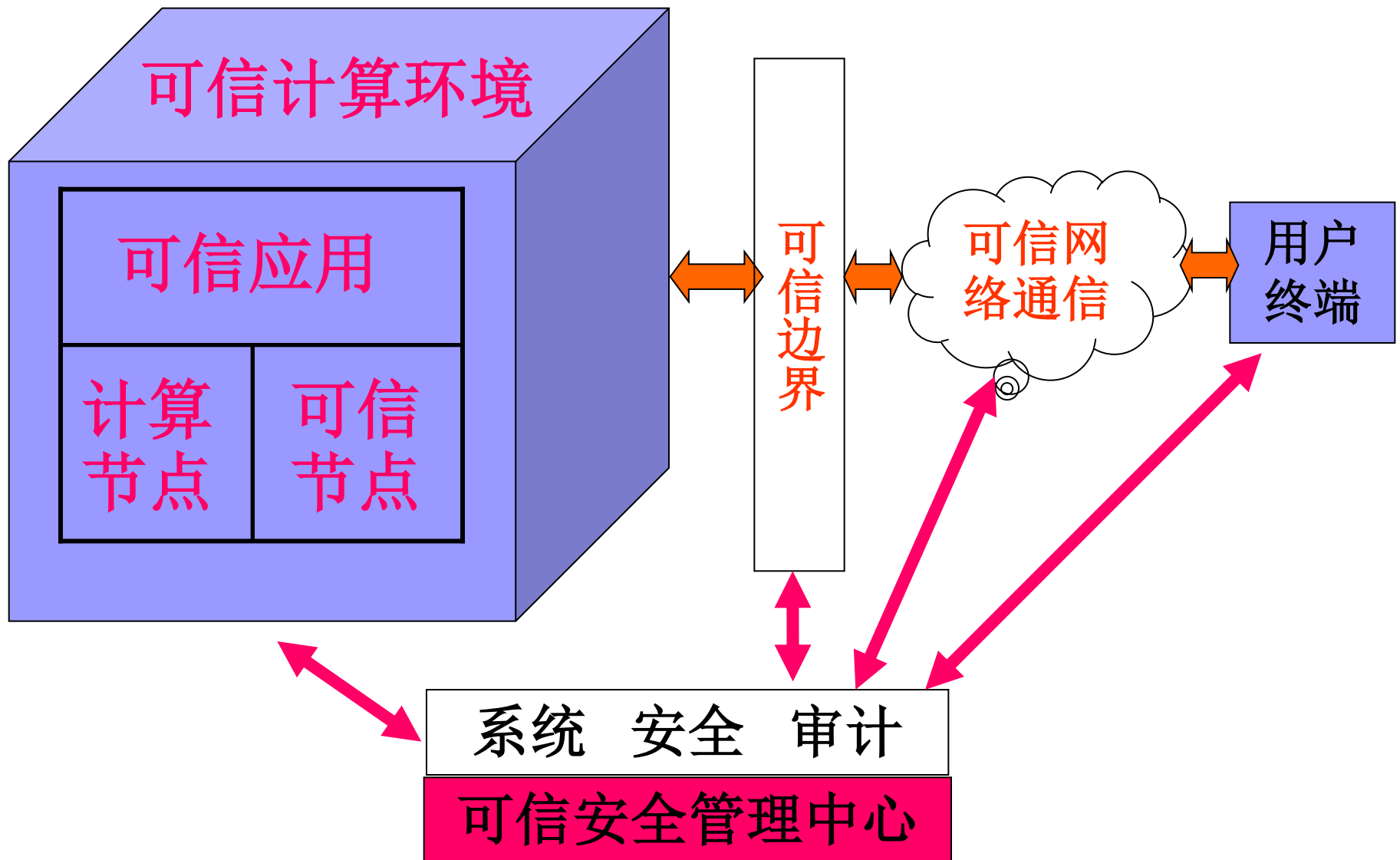
操作行为可信

资源配置可信

数据存储可信

策略管理可信

构建可信安全管理中心支持下的 三重防护框架



安全防护效果

1) 攻击者**进不去**

2) 非授权者重要信息**拿不到**

3) 窃取保密信息**看不懂**

4) 系统和信息篡改**不了**

5) 系统工作**瘫不成**

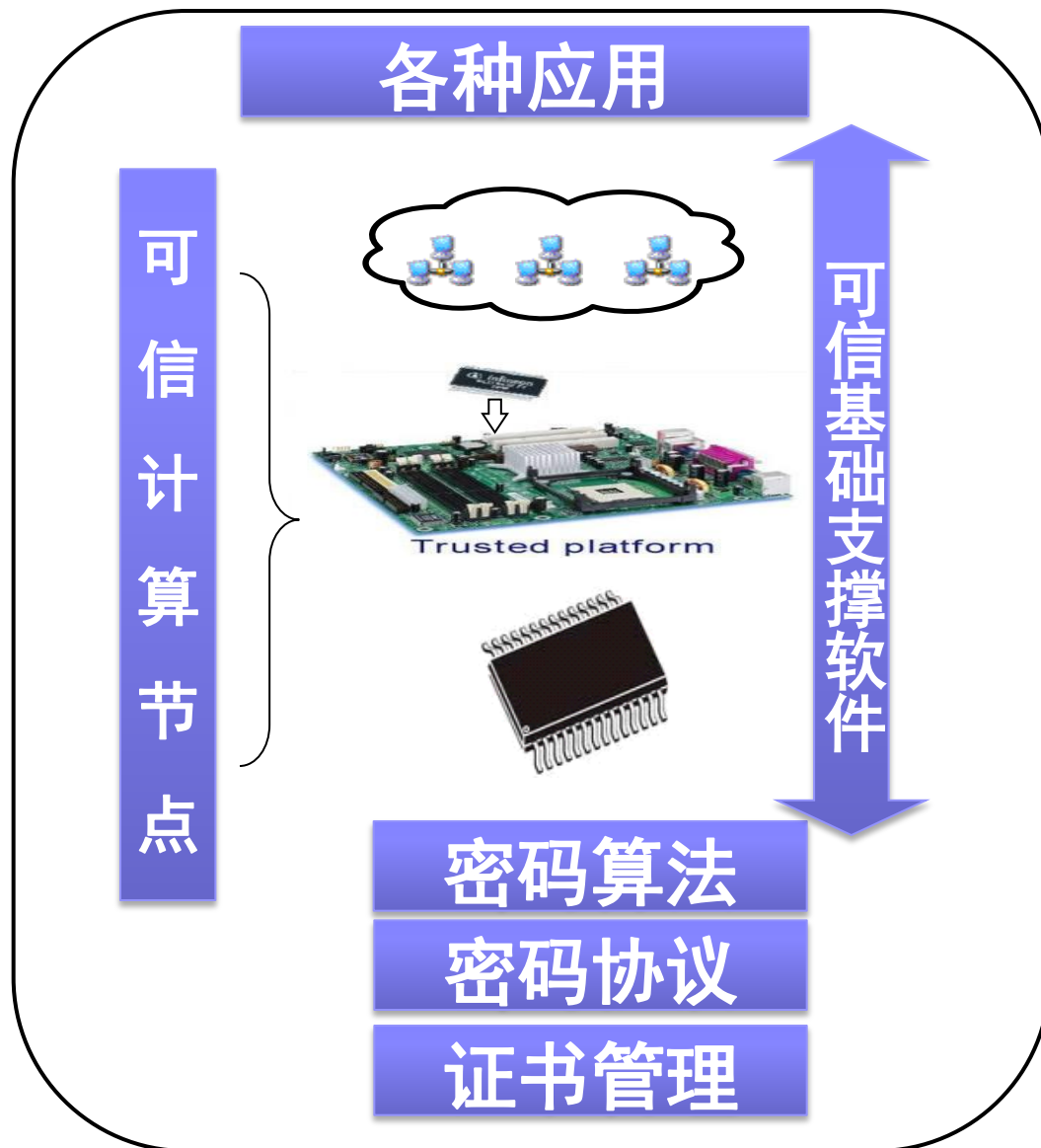
6) 攻击行为**赖不掉**

（二）中国可信计算技术创新

中国可信计算于1992年正式立项研究并规模应用，早于TCG（2000年成立），经过长期攻关，形成了自主创新的体系

(1) 可信计算技术结构框架

- 密码为基础
- 芯片为支柱
- 主板为平台
- 软件为核心
- 网络为纽带
- 应用成体系



可信计算标准体系

打基础

密码标准：自主密码体系

构主体

四个主体标准：芯片、主板、软件、网络

搞配套

四个配套标准：规范结构、服务器、存储、测评

成体系

各种应用相关标准：网站、办公、等保等

(2) TCG可信计算方案局限性

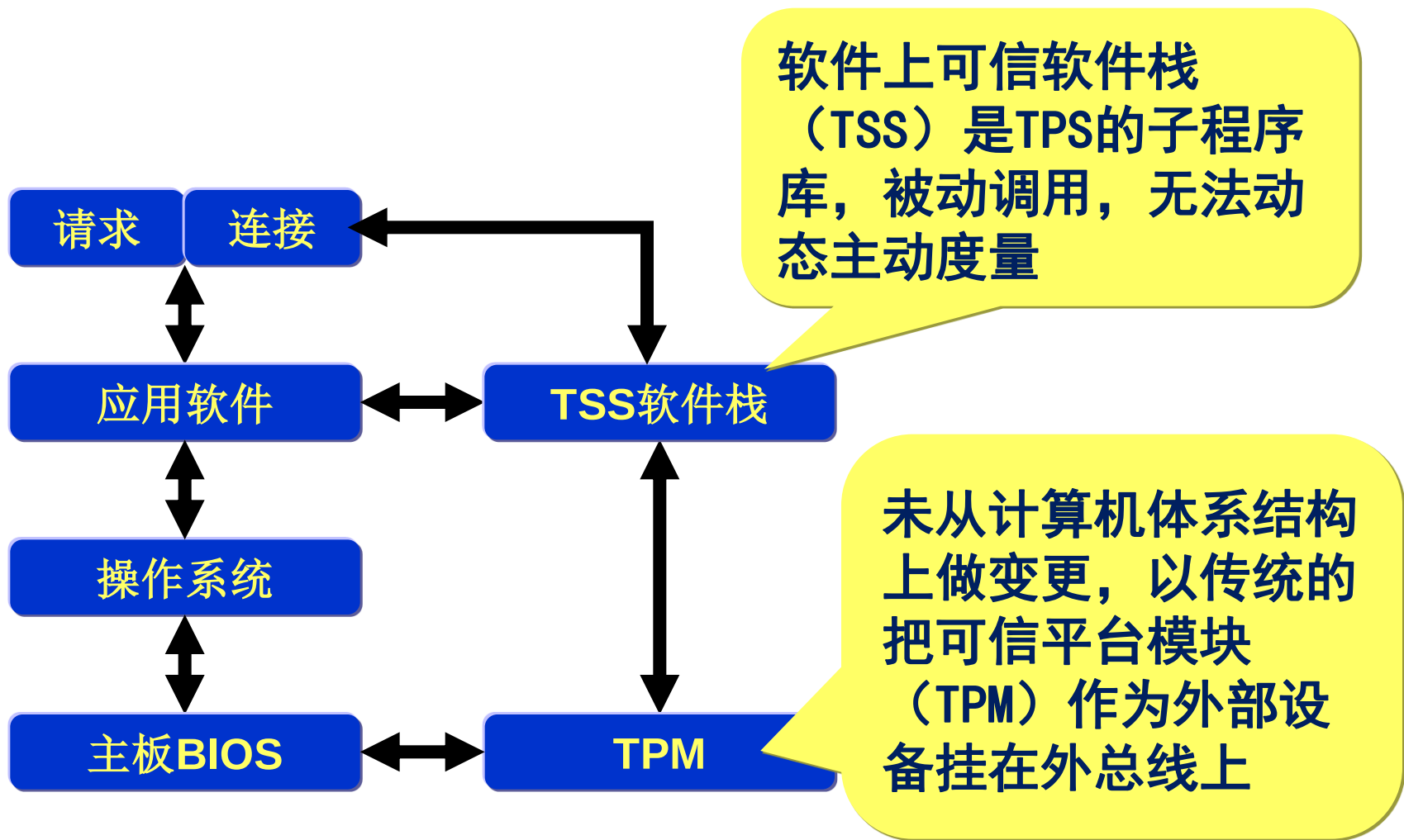
1、密码体制的局限性

TCG公钥密码算法只采用了RSA，杂凑算法只支持SHA1系列，回避了对称密码

由此导致密钥管理、密钥迁移和授权协议的设计复杂化（五类证书，七类密钥），也直接威胁着密码的安全

2、体系结构的不合理

目前还主要停留在工程层面，尚缺乏比较完善的理论模型，TPM外挂，子程序调用被动模式



TCG外挂结构

(3) 中国可信计算创新点

可信计算自主密码方案

芯片层面的主动控制

主板层面的计算和可信双节点融合

软件层面的双系统体系结构

网络层面的三元三层对等架构



双体系结构

（三）解决核心技术受制于人问题

（1）中国可信计算产业化条件具备

《国家中长期科学技术发展（2006-2020年）》明确提出“以发展高可信网络为重点，开发网络安全技术及相关产品，建立网络安全技术保障体系”

“十二五”规划有关工程项目都把可信计算列为发展重点

可信计算标准系列逐步制定，研究制定单位达40多家，参加人员达400多，标准的创新点都作了技术验证，申报专利达40多项

不少单位和部门已按有关标准研制了芯片、整机、软件和网络连接等可信部件和设备，并得到了有效的应用

2014年4月16日，成立了中关村可信计算产业联盟，大力推进产业化、市场化

(2) XP停止服务带来的风险与契机

2014年4月8日，微软公司将正式停止对Windows XP的服务支持

全国约2亿台运行XP操作系统的终端将面临无人服务的局面，安全风险将显著增加

Windows 8和Vista（2006年政府明确不采购）是同类架构，Windows 8与可信平台模块（TPM2.0）绑定，对用户控制能力超过Vista。Windows 8还捆绑了微软的杀毒软件，时刻在检查用户终端，随时可以给用户电脑下载补丁，更容易为“棱镜”项目等监控手段提供支撑

升级为Windows8不仅耗费巨资，还失去安全控制权和二次开发权

中央国家机关政府采购中心发出要求，国家机关进行信息类协议供货强制节能产品采购时，所有计算机类产品不允许安装Windows8操作系统

中央的决定将有力推进基于可信计算的创新的自主可控、安全可信的操作系统研发和产业化

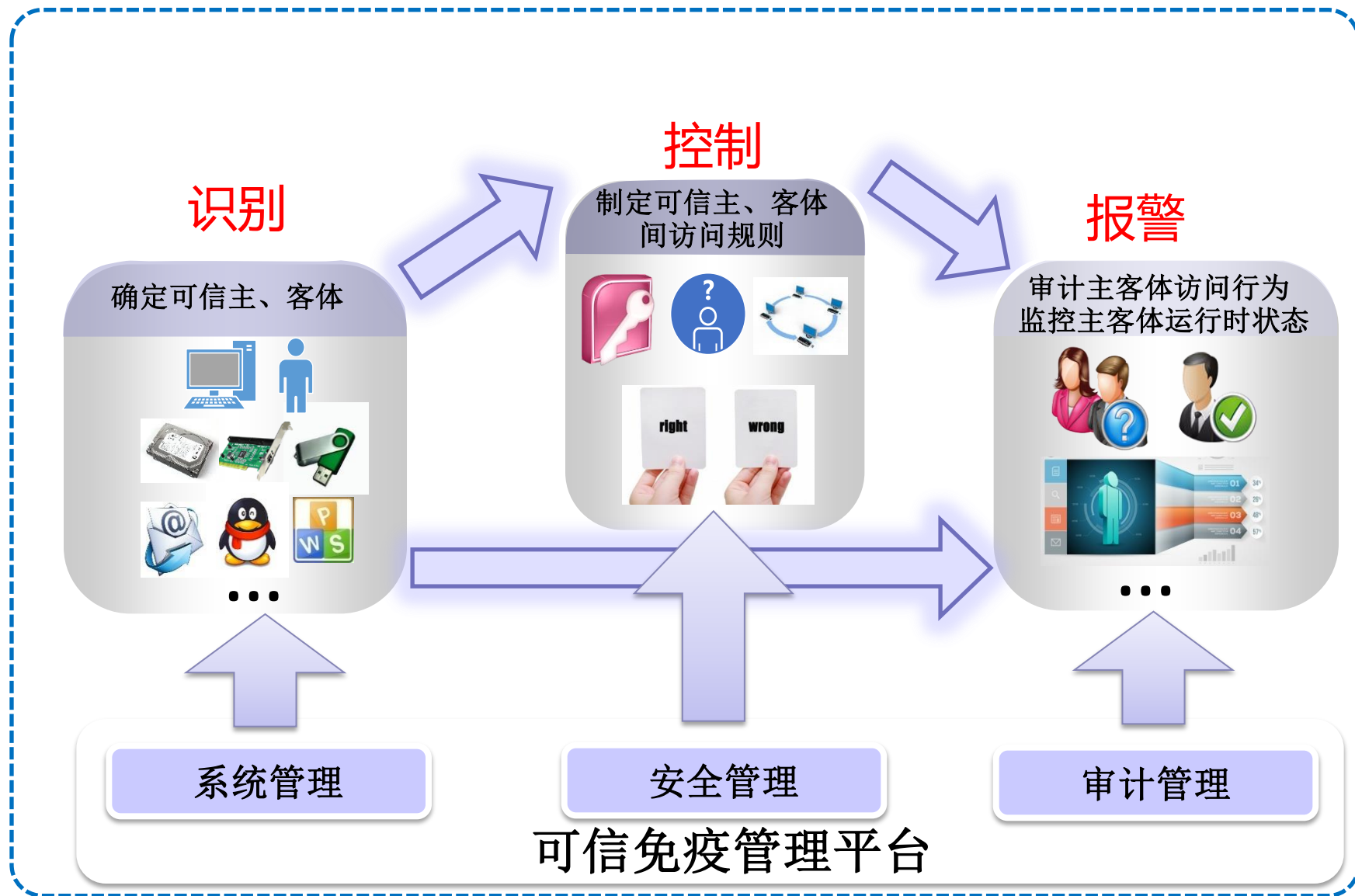
(3) 利用自主创新的可信计算加固XP系统

可信计算平台 硬件上有三种形态：



可以方便的把现有设备升级为可信计算机系统，而应用系统不用改动，便于推广应用，使系统免受新的恶意代码攻击

可信计算构建主动免疫体系



XP停止维护以后，系统免受安全威胁的影响

确定可信状态以后，即使有BUG也不会变成漏洞，使攻击无效

主、客体的可信认证，及时发现异常，环境的非法改变

重要信息保护
系统层透明加解密

防止非法、越权
操作的访问控制

资源可信度量

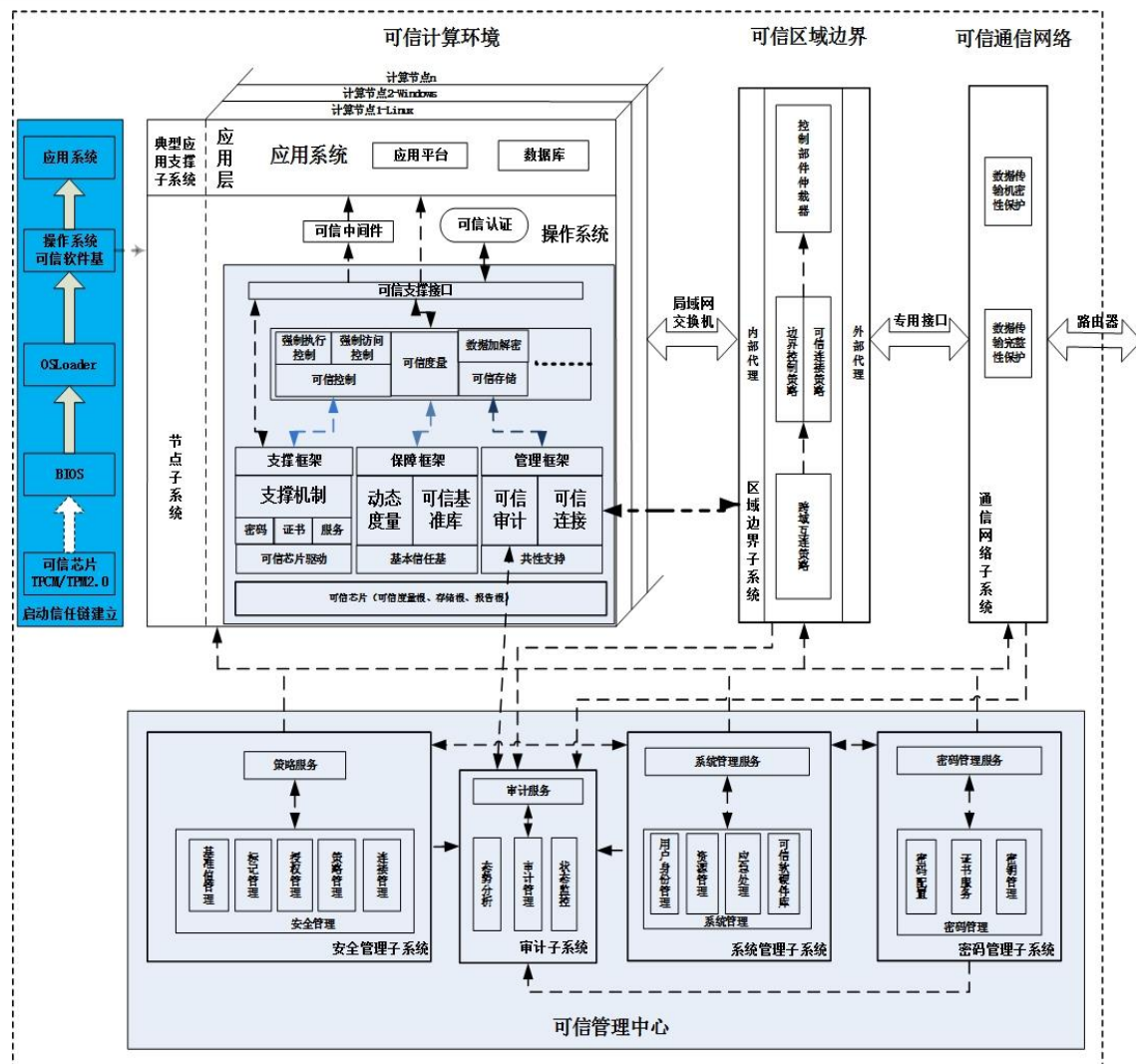
数据可信存储

行为可信鉴别

可信计算

可信防护体系

部署可信计算平台后，原有信息安全防护体系，建立可信免疫的主动防御安全防护体系和高安全等级结构化保护



GB/T25070-2010

(4) 为全面替代国外产品打基础

为国产化替代战略保驾护航

主动免疫系统 特点：

- 免病毒查杀免打补丁
- 不用修改应用软件
- 用户使用完全透明
- 支持异构环境
- 系统效率损耗不到5%

已适配的操作系统

Windows : WindowsXP 、
WINDOWS7、
Server2003、Sever2008 ...

Linux: Redhat 、 Centos、 SuSe、
Redflag、中标麒麟、银河麒麟、凝思磐石...

UNIX: AIX、 Solaris、 HP-UNIX...



以可信服务替代补丁服务

实施部署方便

线下部署方式

重点针对高等级重要系统



主动免疫系统软件

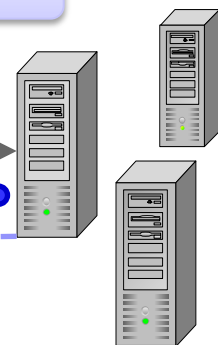


安全管理平台

专网隔离系统

线上部署方式

针对中小型企业以及个人用户



安全管理平台

互联网相连系统

全面支持国产化的硬件、软件。
尽管国产化产品存在更多的缺陷和漏洞，由可信保障，使缺陷和漏洞不被攻击利用，确保比国外产品更安全，为国产化自主可控、安全可信保驾护航

通过演示验证验收、测评以及设计鉴定，已定型10余款

设备：长城、浪潮、曙光、联想、同方等

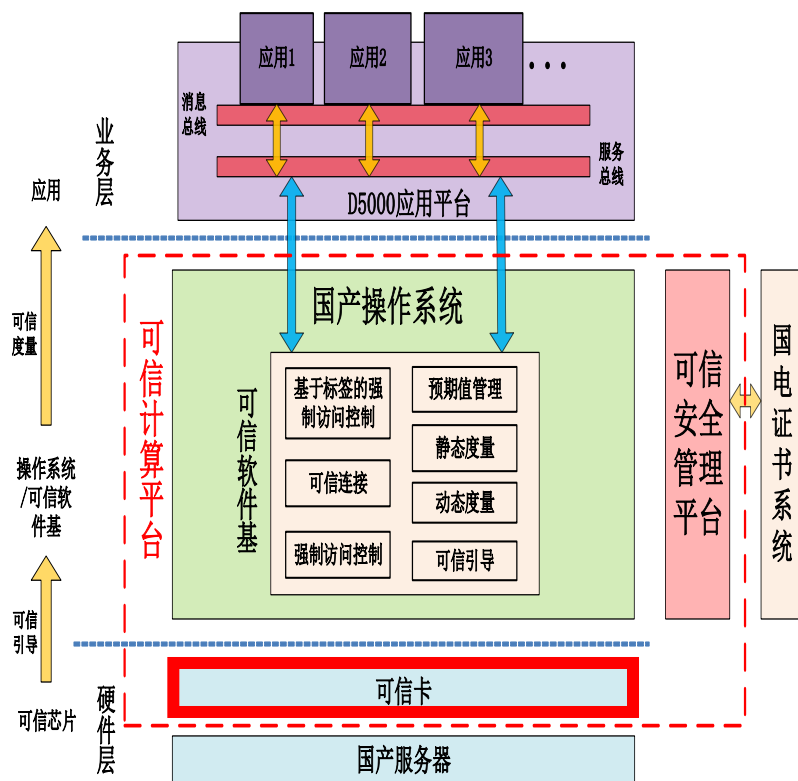
软件：CEC可信软件基

CPU：龙芯、飞腾、众志等

全国国产化示范：国家电网电力调度系统

最近电监委5号行政令决定以可信计算架构实现等级保护四级

高等级专网系统案例-国家电网电力调度系统



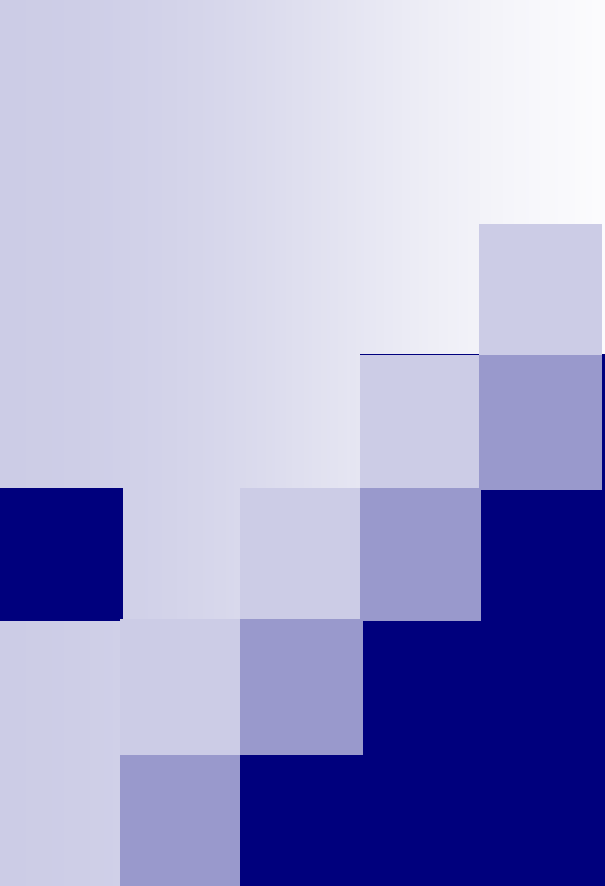
应用	CPU使用率			内存使用率			计算时间		
	加载前	加载后	影响度	加载前	加载后	影响度	加载前	加载后	影响度
应用1	2.92 %	2.95 %	1.03 %	11%	11%	0%	69s	69.9 s	1.3 %
应用2	2.3 %	2.33 %	1.3 %	6.9 %	7%	1.45 %	24.6 s	25.1 s	2.03 %
应用3	2.8 %	2.85 %	1.79 %	7.8 %	7.9 %	1.28 %	18.9 s	19.4 s	2.65 %

- 采用PCI可信卡的方式进行部署实施
- 实现了对已知、未知恶意代码的免疫
- 实现了可信保障机制，使得系统中的安全机制不被旁路或篡改
- 基于D5000平台的安全标签，实现针对服务的强制访问控制

通过逐级认证实现系统的主动免疫，达到等级保护四级技术要求

结束语

面临日益严峻的国际网络空间形势，我们要立足国情，创新驱动，解决受制于人的问题。坚持纵深防御，构建牢固的网络安全保障体系，为我国建设成为世界网络安全强国而努力奋斗！



谢谢大家！